

Phishing Detection & Awareness Report

INCIDENT ANALYSIS & EMPLOYEE SECURITY GUIDELINES

Analyst: Meghana Nalla (Cyber Security Analyst Intern)
Organization: Future Interns
Date: June 2026
Task Phase: Cyber Security Task 2 — Awareness & Header Auditing

1. Executive Summary

Phishing attacks continue to rank as the primary vector for corporate security breaches globally. While hardware perimeter security defenses are standard, attackers exploit human psychological triggers to bypass authentication rings. This report acts as an analytical case study detailing a simulated corporate threat, breaking down its structural flaws, parsing live electronic headers using standard tools, and offering institutional defensive guidelines to reinforce employee operational posture.

2. Incident Profile Case Study

The following mock or captured alert represents a daily credential harvesting threat targeting corporate endpoints:

Subject: ⚠ Urgent: Your Account Will Be Locked
From: Security Team <support@secure-account-verify.com>

Dear User,

We noticed suspicious activity on your account.
To avoid account suspension, please verify your details immediately.

👉 Verify Now: <http://secure-account-verify.com>

Failure to verify within 24 hours will result in permanent account lock.

Regards,
Security Team

3. Key Phishing Indicators Identified

- **Unauthenticated / Generic Salutation:** The email utilizes "Dear User" instead of personal employee directory information. Legitimate security frameworks leverage directory names to build systemic authenticity.

- **Artificial Urgency & Fear Scarcity:** Mandating compliance within an strict "24 hours" window is a social engineering strategy engineered to inhibit logical critical reasoning.
- **Protocol Flaws & Deceptive Domain structures:** The text links directly to <http://secure-account-verify.com>. The use of an unencrypted HTTP pathway over secure HTTPS indicates that no valid SSL/TLS handshakes exist. Furthermore, the domain mimics an official security brand but belongs to an external, malicious registrar registry.

4. Electronic Mail Header Auditing

Using the **Google Admin Toolbox MessageHeader Analyzer**, security professionals look past the visible "From" mask to examine structural routing elements. While a real verified corporate mail flow establishes immediate compliance, malicious payloads leave clear diagnostic indicators:

Technical Metric Focus:

In an active investigation, the analyst monitors the **SPF (Sender Policy Framework)** validation state. A domain mismatch occurs when the sending server's static routing IP is not listed on the official registrar whitelist, producing an immediate **FAIL**. Similarly, cryptographic path alterations invalidate the **DKIM (DomainKeys Identified Mail)** key pair, warning downstream defensive nodes of active spoofing.

5. Risk Classification & Assessment Matrix

Evaluation Metric	Assigned Status	Analytic Determination
Risk Classification	HIGH THREAT	Malicious deployment intended for external credential harvest.
Attack Taxonomy	Credential Harvesting	Leverages domain look-alikes to intercept credentials.
SPF / DKIM Checks	Unverified / Fail	Sender parameters do not align with authenticated corporate roots.

6. Employee Awareness Directives (Do's & Don'ts)

Security Directives (DO)	Prohibited Actions (DON'T)
Hover Before Interaction: Rest the pointer over links to visually confirm the actual destination domain address strings.	Do Not Yield to Urgency: Disregard high-pressure timers requiring rapid profile changes.
Out-Of-Band Authentication: Manually navigate directly through verified internal corporate bookmark directories if an alert states account context has changed.	Do Not Disclose OTPs: No internal operational support team will prompt you for an unencrypted Multi-Factor or password key code.
Immediate Isolation: Forward any discovered unverified threat markers straight to the active institutional SOC tracking queue.	Do Not Interact or Forward: Refrain from opening attachment macro layers (.zip, .xlsm, .exe) or forwarding files to peers.